



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:



The background is a solid blue color with a subtle pattern of binary code (0s and 1s) and circuit-like lines. In the center, there is a large, stylized padlock icon. To the right of the padlock, there is a shield icon. In the bottom left corner, there is a computer monitor icon displaying a shield with a padlock. In the bottom right corner, there is a stylized illustration of an industrial facility with various tanks, pipes, and structures.

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Módulo 5

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

¿Qué es la ISA/IEC 62443?

- La **serie ISA/IEC 62443** es un **conjunto de normas internacionales** diseñadas para abordar los **requisitos de ciberseguridad** de los **sistemas de automatización y control industrial (IACS)**, es decir, los entornos OT (Operational Technology).
- **Objetivo principal:**
Proporcionar un marco de referencia integral para **proteger los activos industriales** frente a amenazas cibernéticas, asegurando la **disponibilidad, integridad y confidencialidad** de los procesos industriales críticos.
- **¿Quién la crea y mantiene?**
- Fue desarrollada por el comité **ISA99** de la **International Society of Automation (ISA)**, organización con sede en EE.UU.
- Actualmente está gestionada conjuntamente por **ISA** e **IEC (International Electrotechnical Commission)** bajo el comité técnico **IEC TC65 / WG10**.
- La **versión internacional oficial** es la publicada por **IEC**, aunque ISA publica versiones prácticamente idénticas.

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

¿A quién se aplica?

La norma ISO/IEC 62443 aplica a todos los actores involucrados en el ecosistema industrial:

Rol	Responsabilidad principal
Propietario de activos	Define requerimientos y gestiona el ciclo de vida de seguridad.
Integradores de sistemas	Implementan arquitecturas seguras y hacen integración OT.
Mantenedores de sistemas	Mantienen sistemas OT durante su ciclo de vida
Proveedores de productos	Diseñan dispositivos (SCADA, PLC, HMI, sensores) con seguridad integrada.

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Estructura de la familia ISA/IEC 62443

- La norma está dividida en **4 partes principales**, cada una con subdocumentos específicos:

Serie	Enfoque principal	Ejemplo de norma
1-X	Conceptos generales	62443-1-1: Terminología y modelos
2-X	Políticas y procedimientos organizativos	62443-2-1: Requisitos de SGSI-OT
3-X	Requisitos de sistema técnico	62443-3-2: Análisis de riesgos y niveles de seguridad
4-X	Requisitos de componentes individuales	62443-4-2: Requisitos técnicos para dispositivos

Se están añadiendo constantemente nuevos documentos e incluso alguna nueva serie

Conceptos fundamentales

Defense in Depth

- Modelo de **defensa en profundidad**, con múltiples capas de seguridad (física, red, lógica, organizativa).

Zonas y Conduits

- **Zonas:** agrupaciones de activos OT con requisitos comunes de seguridad (ej. planta, subestación, laboratorio).
- **Conduits:** los **canales de comunicación** entre zonas, que deben ser **controlados y segmentados**.

Assets (activos)

- Todo elemento (físico o lógico) que forma parte del IACS y debe ser inventariado: PLCs, HMIs, sensores, redes, servidores, software, etc.

Modelo de roles y responsabilidades

- Define claramente los **roles clave** para mantener la ciberseguridad OT:

Rol	Ejemplo de responsabilidad
Asset Owner	Define requisitos, mantiene el ciclo de vida.
System Integrator	Diseña y configura soluciones seguras.
Product Supplier	Proporciona productos que cumplen requisitos técnicos.
Maintenance Provider	Asegura que las actualizaciones no rompen la seguridad.

Implementación práctica

Establecimiento de un SGSI-OT (ISO/IEC 62443-2-1)

- Equivalente a un SGSI de ISO 27001 pero enfocado a OT.
- Incluye políticas, roles, gestión de accesos, proveedores, etc.

Análisis de riesgos (ISO/IEC 62443-3-2)

- Identificación de amenazas, vulnerabilidades y escenarios OT.
- Se asigna un **Security Level Target (SL-T)** de 1 a 4 según criticidad.

Diseño de arquitectura OT segura (ISO/IEC 62443-3-3)

- Aplicación de controles: autenticación, control de accesos, cifrado, registros, etc.
- Aplicación de seguridad basada en zonas y conduits.

Selección de dispositivos seguros (ISO/IEC 62443-4-2)

- Se exige que PLCs, routers industriales, gateways y HMIs cumplan con requisitos técnicos definidos.

Niveles de seguridad (Security Levels - SL)

SL	Protección contra...	Ejemplo
SL0	No necesita protección	Un panel informativo
SL1	Accidental / casual	Configuración básica de firewall
SL2	Ataques con recursos limitados	Segmentación, control de acceso
SL3	Ataques con recursos organizados	Detección, cifrado, redundancia
SL4	Amenazas altamente sofisticadas	Aislamiento físico, monitorización continua

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Factores de éxito

- Apoyo de la dirección.
- Involucrar desde el principio a OT e ingeniería.
- Formación continua.
- Documentación de arquitectura, procedimientos y roles.
- Monitorización activa (SOC OT).
- Evaluaciones periódicas y actualización de riesgos.

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Relación con ISO/IEC 27001

ISO/IEC 27001	ISA/IEC 62443
Sistemas IT empresariales	Sistemas OT e IACS
Seguridad de la información	Seguridad operacional + física
Generalista	Específica para entornos industriales
SGSI basado en riesgos	SGSI-OT + requisitos técnicos

Recomendación: Integrar ambas como parte de un sistema de gestión conjunto IT/OT

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Subcomités y regulación

- **IEC TC65 / WG10:** grupo técnico encargado de la norma.
- **ISA/IEC 99:** origen de la norma.
- No es obligatoria por ley, pero:
- Es usada como **referencia técnica en NIS2** y otras normativas.
- Es base para certificaciones industriales (ej. TÜV, ISASecure).
- **Algunas industrias (como automoción o energía)** la exigen contractualmente.

ISA/IEC 62443: Ciberseguridad en Sistemas de Automatización y Control Industrial (IACS)

Casos de uso y buenas prácticas

- Integración de herramientas tipo SIEM en redes OT.
- Segmentación de redes y control de accesos por zonas lógicas.
- Uso de gateways con inspección profunda de paquetes (DPI).
- Evaluación de vulnerabilidades de dispositivos OT (VA).
- Formación de los operadores industriales y técnicos.

Recursos y herramientas útiles

- **ISASecure**: certificación basada en ISO/IEC 62443 para productos e integradores.
- **CyberPHA**: metodología para análisis de riesgos OT basada en HAZOP + ciber.
- **Plantillas de zonas y conduits** publicadas por ISA.
- **Herramientas de arquitectura tipo IACS Reference Architectures**.